

GIAN GIEN VINCENT D. GARON
ARTHUR DALE ENRIQUE U. MICAROL
RONNIE LAURENCE T. TIEMPO

25/09/2025

CYBER SECURITY

PART 1: TASK: "SOMETHING YOU KNOW, HAVE, ARE"

- 1.1) LENGTH & COMPLEXITY: ALL PASSWORDS MUST BE AT LEAST 8 OR 12 MORE CHARACTERS LONG & CONTAIN A COMBINATION OF UPPERCASE, LOWERCASE LETTERS, NUMBERS, AND SPECIAL SYMBOLS.
- 1.2) UPDATES & REUSE: PASSWORDS MUST BE CHANGED EVERY 90 DAYS & CANNOT REUSE THE LAST FIVE PASSWORDS.
- 1.3) NO COMMON WORDS: EMPLOYEES ARE FORBIDDEN FROM USING DICTIONARY WORDS, BIRTHDAYS, OR PREDICTABLE SEQUENCES.
- 2) BEYOND PASSWORDS: "AUTHENTICATOR APP" WOULD BE ONE RECOMMENDED APP FOR ADDITIONAL AUTHENTICATION PHASE (SOMETHING YOU HAVE) USE, GOOGLE AUTHENTICATOR, AUTHN, BECAUSE OF THEIR "LOW COST", "EASY TO IMPLEMENT", "WORKS OFFLINE", AND "SECURITY" EVEN A HACKER STEALS A PASSWORD, THEY WOULD STILL NEED EMPLOYEES PHONE TO GET THE (TOTP) "TIME-BASE ONE-TIME CODE".
- 3) MULTIFACTOR AUTHENTICATION (MFA): WITH YOUR PASSWORD AND A "AUTHENTICATOR APP" (SOMETHING YOU HAVE), THE PROCESS FOR MFA WOULD BE; FIRST EMPLOYEE LOGS IN WITH USERNAME & PASSWORD, THEN THE SYSTEM GIVES 6 DIGIT ONE-TIME PASSWORD/CODE BY THE AUTHENTICATOR APP. IT PREVENTS ACCOUNT COMPROMISE IF A PASSWORD IS LEAKED.

PART 2: CONTROLLING ACCESS

- 1.) PRINCIPLE OF LEAST PRIVILEGE: IN MY OPINION, IT SHOULD BE GIVEN ONLY THE MINIMUM LEVEL OF ACCESS REQUIRED TO PERFORM THEIR JOB, NO MORE, NO LESS AND IT IS IMPORTANT PRINCIPLE FOR "INNOVATE LAB" BECAUSE IT PREVENTS ACCIDENTAL DAMAGE, LIKE DELETING FINANCIAL RECORDS, REDUCES INSIDER THREAT DUE TO A ~~ROLE~~ ^{ROLE} BASED ACCESS CONTROL, AND IF AN ATTACKER COMPROMISES ONE ACCOUNT, THEY CANNOT ACCESS ALL OF THE SYSTEM.

2.) ROLE-BASED-ACCESS-CONTROL (RBAC)

ROLE	CLIENT DATABASE	FINANCIAL RECORDS
DEVELOPER	READ, WRITE	NO ACCESS
MARKETING	READ	NO ACCESS
FINANCE	READ (BILLING INFO ONLY)	READ, WRITE
SYSADMIN	FULL CONTROL	FULL CONTROL

- 3.) GRANULARITY: IN THE "FINANCE ROLE" SHOULD HAVE "WRITE ACCESS" TO "INVOICES" BUT NOT TO "PAYROLL" SINCE IT CONTAINS SENSITIVE EMPLOYEE DATA, WHILE "MARKETING ROLE" SHOULD HAVE NO ACCESS AT ALL TO FINANCIAL RECORDS. IT ENSURES SENSITIVE DATA IS TIGHTLY RESTRICTED.

PART 3: SHORT REFLECTION

AUTHENTICATION ENSURES THAT ONLY AUTHORIZED EMPLOYEES CAN LOGIN, WHILE ACCESS CONTROL ENSURES THEY CAN ONLY PERFORM THE TASKS FIT FOR THEIR ROLE. THESE CREATE A LAYERED DEFENSE IF SOMEONE STEALS A PASSWORD, THEY CANNOT ACCESS SENSITIVE FILES WITHOUT PASSING MFA & CORRECT ROLE RESTRICTIONS. A SYSTEM WITH ONLY AUTHENTICATION IS WEAK BECAUSE A VALID USER COULD STILL ACCESS EVERYTHING, WHILE A SYSTEM WITH ONLY ACCESS CONTROL IS ALSO WEAK BECAUSE ATTACKERS COULD IMPERSONATE USERS. SO BOTH ARE REQUIRED FOR A TRULY SECURE COMPANY SYSTEM.